

# Reporte Ejecutivo

Gestión de Riesgos de Seguridad de la Información  
Clínica Privada — Implementación con SimpleRisk

|         |                       |        |            |
|---------|-----------------------|--------|------------|
| Alumno  | Nicolás Estrella      | Legajo | 31.066.692 |
| Materia | Seguridad de Sistemas | Fecha  | 10/09/2026 |

## 1. Resumen Ejecutivo

Se llevó a cabo un proceso de gestión de riesgos de seguridad de la información para una clínica privada de 120 empleados y aproximadamente 800 pacientes atendidos por día, que opera con historias clínicas electrónicas (HCE), gestiona datos de obras sociales y terceriza parte de su facturación. El análisis se realizó utilizando **SimpleRisk**, una herramienta open source de gestión de riesgos, desplegada mediante Docker.

Se identificaron y documentaron **7 riesgos** relevantes para el negocio, se definieron **3 usuarios con roles diferenciados** (Administrador, Analista de Riesgos y Auditor) bajo el principio de menor privilegio, y se elaboraron **3 planes de acción** para los riesgos de mayor criticidad. El hallazgo principal es que el riesgo más grave para la organización es un ataque de **ransomware sobre el servidor de historias clínicas**, calificado como Alto, seguido de riesgos de nivel Medio vinculados al acceso indebido a información de pacientes y a la falta de una política formal de backups.

## 2. Riesgos Identificados

La siguiente tabla resume los 7 riesgos relevados, ordenados por nivel de criticidad (probabilidad × impacto), calculados con el método clásico de SimpleRisk:

| ID   | Riesgo                                  | Categoría                       | Prob.    | Impacto              | Nivel       |
|------|-----------------------------------------|---------------------------------|----------|----------------------|-------------|
| 1002 | Ransomware en servidor de HCE           | Gest. vulnerabilidades técnicas | Probable | Extremo/Catastrófico | Alto (8)    |
| 1009 | Acceso indebido a HCE por personal      | Gestión de acceso               | Probable | Importante           | Medio (6.4) |
| 1007 | Phishing a personal administrativo      | Política y procedimiento        | Probable | Importante           | Medio (6.4) |
| 1010 | Pérdida de datos por falta de backups   | Gest. vulnerabilidades técnicas | Creíble  | Extremo/Catastrófico | Medio (6)   |
| 1005 | Filtración por proveedor de facturación | Gestión de terceros             | Creíble  | Importante           | Medio (4.8) |
| 1006 | Caída del sistema por falta de UPS      | Resiliencia ambiental           | Probable | Moderado             | Medio (4.8) |
| 1008 | Incumplimiento Ley 25.326               | Política y procedimiento        | Creíble  | Importante           | Medio (4.8) |

*Nota: se cuenta además con un usuario de tres roles diferenciados (Administrador, Analista de Riesgos, Auditor) configurados con permisos ajustados a su función, y un riesgo de prueba (ID 1001) utilizado únicamente para validar el funcionamiento inicial del sistema.*

## 3. Planes de Acción Prioritarios

Para los tres riesgos de mayor criticidad se definieron planes de mitigación concretos, con responsable, esfuerzo estimado y fecha objetivo de implementación:

**1. Ransomware en servidor de HCE (ID 1002 — Alto).** Implementación de backups automatizados diarios con almacenamiento aislado (air-gapped/inmutable), una solución EDR en el servidor y segmentación de red. Esfuerzo: Significativo. Vencimiento: 08/11/2026.

**2. Phishing al personal administrativo (ID 1007 — Medio, 6.4).** Programa de capacitación periódica en concientización de seguridad, simulacros de phishing trimestrales y autenticación multifactor (MFA) obligatoria en

accesos críticos. Esfuerzo: Considerable. Vencimiento: 12/10/2026.

**3. Acceso indebido a HCE (ID 1009 — Medio, 6.4).** Control de acceso basado en roles (RBAC) según necesidad de conocer, junto con registro y auditoría periódica de accesos al sistema. Esfuerzo: Considerable. Vencimiento: 12/09/2026.

## 4. Conclusiones

El relevamiento confirma que los mayores riesgos de la clínica están vinculados a la ausencia de controles técnicos básicos (backups probados, segmentación de red, MFA) más que a la falta de voluntad organizacional. Priorizar el plan de mitigación del riesgo de ransomware es crítico, dado que su materialización combina alta probabilidad con el mayor impacto posible: interrupción total de la atención a pacientes y pérdida irrecuperable de historias clínicas. Se recomienda revisar el estado de estos tres planes de acción en un plazo no mayor a 60 días.